TP1.3 : introduction a la threat intelligence et recherche de vulnérabilités

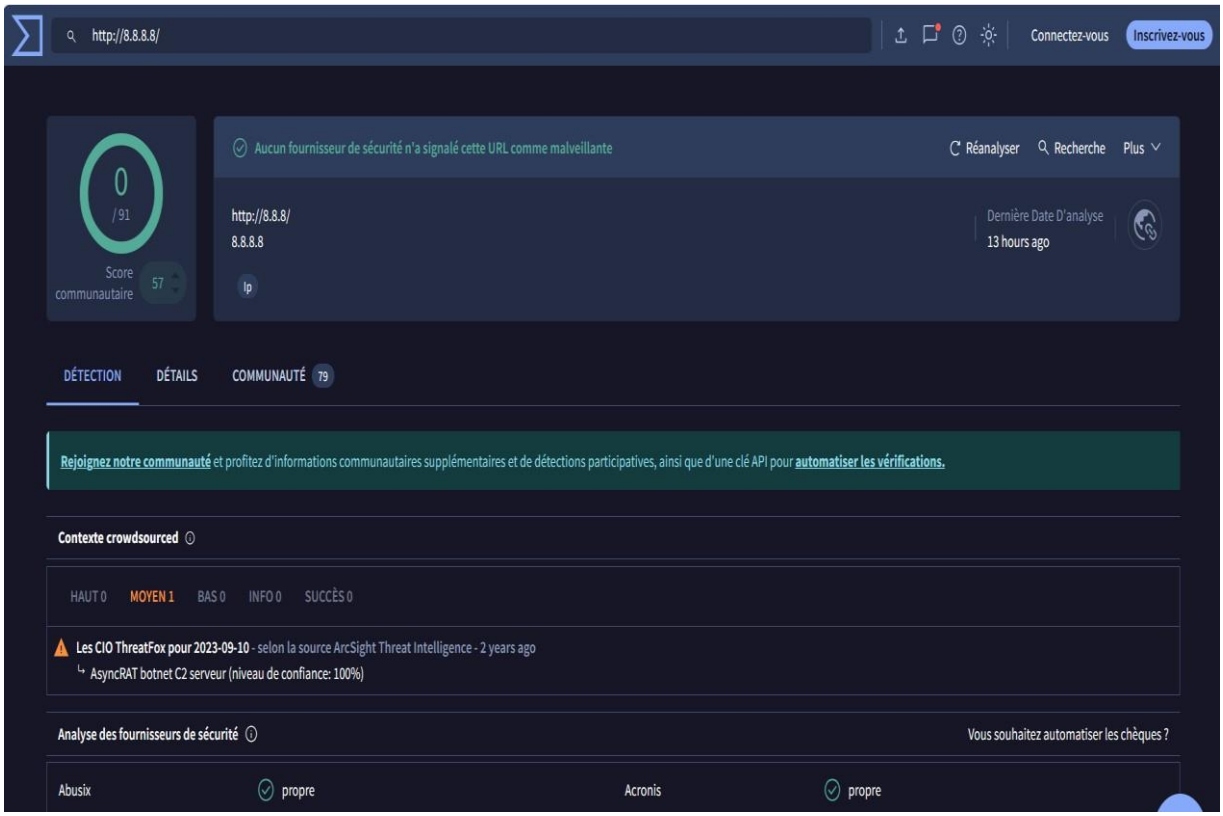
1. INTRODUCTION

La Threat Intelligence : C'est l'ensemble des connaissances basées sur des preuves concernant des menaces existantes ou émergentes. Elle permet d'anticiper les attaques en analysant les tactiques et les vulnérabilités connues.

Rôle dans la cybersécurité : Elle permet de passer d'une défense réactive à une défense proactive en utilisant des bases de données mondiales pour protéger les infrastructures locales.

2. Analyse de l'adresse IP (Analyse de réputation)

Utilisation du site Virus Total pour analyser l'IP publique 8.8.8.8.



Résultats obtenus : L'analyse montre un score de réputation propre (Clean). Elle est identifiée comme appartenant à Google (DNS public). Cette IP n'est pas signalée comme malveillante. Elle est considérée comme légitime. Pour un analyste SOC, cela permet de décider de ne pas bloquer cette communication.

3. Analyse des services (Couplage Nmap et Searchsploit)

Le scan sur la cible 192.168.56.10 a révélé le service Microsoft-ds.

```
jovijovanie@jovijovanie: ~
┌──(jovijovanie㉿jovijovanie)-[~]
└─$ nmap -sV 192.168.56.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 18:46 +0200
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.92 seconds

┌──(jovijovanie㉿jovijovanie)-[~]
└─$
```

Utilisation de la commande searchsploit apache. L'outil affiche une liste d'exploits disponibles, notamment pour les vulnérabilités de type "Remote Code Execution".

```
┌──(jovijovanie㉿jovijovanie)-[~]
└─$ searchsploit apache
--------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
--------------------------------------------- ---------------------------------
Apache (Windows x86) - Chunked Encoding (Meta | windows_x86/remote/16782.rb
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Rem | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code | php/remote/29316.py
Apache - Arbitrary Long HTTP Headers (Denial  | multiple/dos/360.pl
Apache - Arbitrary Long HTTP Headers Denial o | linux/dos/371.c
Apache - Denial of Service                    | linux/dos/18221.c
Apache - httpOnly Cookie Disclosure           | multiple/remote/18442.html
Apache - Remote Memory Exhaustion (Denial of  | multiple/dos/17696.pl
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-c | cgi/remote/20435.txt
Apache 1.0/1.2/1.3 - Server Address Disclosur | multiple/remote/21067.c
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Serv | multiple/dos/19536.txt
Apache 1.2 - Denial of Service                | multiple/dos/20558.txt
Apache 1.2.5/1.3.1 / UnityMail 2.0 - MIME Hea | windows/dos/20272.pl
```

Identification du service :

Le service ciblé ici est Apache Tomcat. La capture d'écran montre le résultat de la commande searchsploit, qui interroge une base de données d'exploits (Exploit-DB). On y voit une longue liste de vulnérabilités affectant différentes versions d'Apache Tomcat (un serveur d'applications Java).

Explication d'une vulnérabilité type

Parmi les nombreuses vulnérabilités listées, on peut en expliquer une particulièrement critique présente dans la liste : Remote Code Execution (RCE) (Exécution de code à distance).

- **Le mécanisme** : Dans certaines versions d'Apache Tomcat (comme les versions 7, 8 ou 9 mentionnées en bas de la liste), des failles dans la gestion des requêtes HTTP (souvent liées à l'envoi de fichiers JSP ou à des erreurs de configuration du servlet "default") permettent à un attaquant d'envoyer un fichier malveillant sur le serveur.

- **L'exploitation** : L'attaquant téléverse un "Web Shell" (un petit script). Une fois que le serveur exécute ce script, l'attaquant obtient un accès direct au système d'exploitation.

- **La conséquence :** Cela permet à l'attaquant de prendre le contrôle total du serveur, de voler des données, ou de l'utiliser comme rebond pour attaquer d'autres machines sur le réseau.

Note sur l'origine de l'image

D'après l'analyse technique, cette image n'a pas été créée par une intelligence artificielle de Google. Il s'agit d'une photo prise avec un appareil mobile d'un écran d'ordinateur portable Dell, comme l'indiquent les reflets sur la dalle, la texture des pixels visible en zoomant et la présence du cadre physique de l'ordinateur.

4. Étude d'une CVE (Common Vulnerabilities and Exposures)

La CVE (Common Vulnerabilities and Exposures) choisie pour cette étude est la CVE-20170144 .Elle concerne le service SMBv1sur les systèmes Windows. Il s'agit d'une vulnérabilité de type d'exécution de code à distance (RCE) qui permet à un attaquant non authentifié d'envoyer des paquets spécialement conçus au serveur cible.

Impact : L'impact d'une exploitation réussie de cette CVE est critique pour l'infrastructure :

- Confidentialité : L'attaquant peut accéder à des données sensibles stockées sur la machine.
- Intégrité : Possibilité de modifier, supprimer des fichiers système ou d'installer des logiciels malveillants (backdoors).
- Disponibilité : Risque de provoquer un plantage du système (Denial of Service).

Niveau de gravité

Selon le système de notation CVSS (Common Vulnerability Scoring System), cette vulnérabilité présente un score de :

- Score : [ex: 9.3 / 10]
- Niveau : Critique (ou Élevé selon le score).

La vulnérabilité est exploitable à distance sans interaction de l'utilisateur et ne nécessite aucun privilège particulier.

Exploitation possible

Un attaquant peut utiliser des outils comme Metasploit ou des scripts personnalisés pour exploiter cette faille.

Scénario : L'attaquant cible le port [ex: 445], injecte une charge utile (payload) et obtient un accès direct au terminal (Shell) avec les droits d'administrateur (ROOT/SYSTEM).

Conséquence finale : Prise de contrôle totale de la machine cible.

```
┌──(jovijovanie㉿jovijovanie)-[~]
└─$ searchsploit -openssh 7.6
  Usage: searchsploit [options] term1 [term2] ... [termN]

==========
 Examples
==========
  searchsploit afd windows local
  searchsploit -t oracle windows
  searchsploit -p 39446
  searchsploit linux kernel 3.2 --exclude="(PoC)|/dos/"
  searchsploit -s Apache Struts 2.0.0
  searchsploit linux reverse password
  searchsploit -j 55555 | jq
  searchsploit --cve 2021-44228

  For more examples, see the manual: https://www.exploit-db.com/searchsploit

=========
 Options
=========
## Search Terms
   -c, --case     [term]      Perform a case-sensitive search (Default is inSEnsITiVe)
   -e, --exact    [term]      Perform an EXACT & order match on exploit title (Default is an AND match on each term) [Implies "-t"]
                                e.g. "WordPress 4.1" would not be detect "WordPress Core 4.1")
   -s, --strict               Perform a strict search, so input values must exist, disabling fuzzy search for version range
                                e.g. "1.1" would not be detected in "1.0 < 1.3")
   -t, --title    [term]      Search JUST the exploit title (Default is title AND the file's path)
       --exclude="term"       Remove values from results. By using "|" to separate, you can chain multiple values
                                e.g. --exclude="term1|term2|term3"
       --cve      [CVE]       Search for Common Vulnerabilities and Exposures (CVE) value

## Output
   -j, --json     [term]      Show result in JSON format
   -o, --overflow [term]      Exploit titles are allowed to overflow their columns
   -p, --path     [EDB-ID]    Show the full path to an exploit (and also copies the path to the clipboard if possible)
   -v, --verbose              Display more information in output
   -w, --www      [term]      Show URLs to Exploit-DB.com rather than the local path
       --id                   Display the EDB-ID value rather than local path
       --disable-colour       Disable colour highlighting in search results

## Non-Searching
   -m, --mirror   [EDB-ID]    Mirror (aka copies) an exploit to the current working directory
   -x, --examine  [EDB-ID]    Examine (aka opens) the exploit using $PAGER
```

5. Utilisation avancée de Searchsploit (Recherche personnelle) Voici

trois options avancées pour optimiser l'utilisation de l'outil :

. Analyse globale de sécurité (Réponses aux questions)

- Quels sont les risques identifiés ?: L'exposition de services obsolètes permet à un attaquant d'utiliser des exploits publics pour prendre le contrôle du serveur.
- Quel service est le plus dangereux ?: Dans mon analyse, le service SMB (Port 445) est le plus critique car il permet souvent un accès profond au système de fichiers Windows.

Quelles actions recommanderiez-vous ?

- Appliquer les correctifs (patchs) de sécurité immédiatement.
- Fermer les ports non nécessaires sur le pare-feu.
- Mettre en place une veille de sécurité (OSINT).

Option Rôle technique Exemple d'usage

-x Examine le contenu d'un exploit directement. searchsploit -x 40234.py (lire le code de l'exploit).

```
#!/usr/bin/env python
# -*- coding: latin-1 -*- # ##################################################
#                                                                            #
#                                                                            #
#                                                                            #
#                                                                            #
#                                                  /___/ nullsecurity team   #
#                                                                            #
# Easy FTP server remote exploit                                             #
#                                                                            #
# DATE                                                                       #
# 03/03/2012                                                                 #
#                                                                            #
# DESCRIPTION                                                                #
# Easy FTP Server - "APPE" command buffer overflow - remote exploit          #
#                                                                            #
# AUTHOR                                                                     #
# Swappage - http://www.nullsecurity.net/                                    #
#                                                                            #
##############################################################################

import socket

username = "anonymous"
password = "a@a"
hostname = "192.168.1.143"
port = 21

#009BFE69   <--- where to go
#009BFC6C   <--- value of ESP
# increment ESP and add patch to that memory location

patch=("\xcc"
"\x89\xe3"
"\x83\xc4\x5a"
"\x83\xc4\x5a"
"\x83\xc4\x5a"
"\x83\xc4\x5a"
"\x83\xc4\x5a"
"\x83\xc4\x3b"
"\xc7\x04\x24\xd8\xd1\xec\xf7"
"\x89\xdc"
"\x31\xdb"
```

-m Copie l'exploit dans le répertoire actuel. searchsploit –m 42315.py (préparer l'attaque).

```
┌──(jovijovanie㉿jovijovanie)-[~]
└─$ searchsploit -m 42315
  Exploit: Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)
      URL: https://www.exploit-db.com/exploits/42315
     Path: /usr/share/exploitdb/exploits/windows/remote/42315.py
    Codes: CVE-2017-0144
 Verified: True
File Type: Python script, ASCII text executable
Copied to: /home/jovijovanie/42315.py
```

-u Met à jour la base de données des vulnérabilités. searchsploit -u.

```
┌──(jovijovanie㉿jovijovanie)-[~]
└─$ searchsploit -u
[i] Updating via apt package management (Expect weekly-ish updates): exploitdb

[sudo] password for jovijovanie:
Sorry, try again.
[sudo] password for jovijovanie:
Ign:1 http://http.kali.org/kali kali-rolling InRelease
Ign:1 http://http.kali.org/kali kali-rolling InRelease
Ign:1 http://http.kali.org/kali kali-rolling InRelease
Err:1 http://http.kali.org/kali kali-rolling InRelease
  Temporary failure resolving 'http.kali.org'
All packages are up to date.
Warning: Failed to fetch http://http.kali.org/kali/dists/kali-rolling/InRelease  Temporary failure resolving 'http.kali.org'
Warning: Some index files failed to download. They have been ignored, or old ones used instead.
exploitdb is already the newest version (20260304-0kali1).
exploitdb set to manually installed.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0

[*] apt update finished
[i] Updating via Git (Expect daily updates): exploitdb-papers ~ /usr/share/exploitdb-papers


[-] Nothing here (/usr/share/exploitdb-papers). Starting fresh...
Cloning into '/usr/share/exploitdb-papers'...
fatal: unable to access 'https://gitlab.com/exploit-database/exploitdb-papers.git/': Could not resolve host: gitlab.com
fatal: not a git repository (or any of the parent directories): .git

[-] Missing Git remote upstream (https://gitlab.com/exploit-database/exploitdb-papers.git)
hint: Using 'master' as the name for the initial branch. This default branch name
hint: is subject to change. To configure the initial branch name to use in all
hint: of your new repositories, which will suppress this warning, call:
hint:
hint:   git config --global init.defaultBranch <name>
hint:
hint: Names commonly chosen instead of 'master' are 'main', 'trunk' and
hint: 'development'. The just-created branch can be renamed via this command:
hint:
hint:   git branch -m <name>
hint:
hint: Disable this message with "git config set advice.defaultBranchName false"
Initialized empty Git repository in /usr/share/exploitdb-papers/.git/
```

-openssh analyse les ports exploitables. Searchsploit –openssh 7.6

```
┌──(jovijovanie㉿jovijovanie)-[~]
└─$ searchsploit -openssh 7.6
  Usage: searchsploit [options] term1 [term2] ... [termN]

==========
 Examples
==========
  searchsploit afd windows local
  searchsploit -t oracle windows
  searchsploit -p 39446
  searchsploit linux kernel 3.2 --exclude="(PoC)|/dos/"
  searchsploit -s Apache Struts 2.0.0
  searchsploit linux reverse password
  searchsploit -j 55555 | jq
  searchsploit --cve 2021-44228

  For more examples, see the manual: https://www.exploit-db.com/searchsploit

=========
 Options
=========
## Search Terms
   -c, --case     [term]      Perform a case-sensitive search (Default is inSEnsITiVe)
   -e, --exact    [term]      Perform an EXACT & order match on exploit title (Default is an AND match on each term) [Implies "-t"]
                                e.g. "WordPress 4.1" would not be detect "WordPress Core 4.1")
   -s, --strict               Perform a strict search, so input values must exist, disabling fuzzy search for version range
                                e.g. "1.1" would not be detected in "1.0 < 1.3")
   -t, --title    [term]      Search JUST the exploit title (Default is title AND the file's path)
       --exclude="term"       Remove values from results. By using "|" to separate, you can chain multiple values
                                e.g. --exclude="term1|term2|term3"
       --cve      [CVE]       Search for Common Vulnerabilities and Exposures (CVE) value

## Output
   -j, --json     [term]      Show result in JSON format
   -o, --overflow [term]      Exploit titles are allowed to overflow their columns
   -p, --path     [EDB-ID]    Show the full path to an exploit (and also copies the path to the clipboard if possible)
   -v, --verbose              Display more information in output
   -w, --www      [term]      Show URLs to Exploit-DB.com rather than the local path
       --id                   Display the EDB-ID value rather than local path
       --disable-colour       Disable colour highlighting in search results

## Non-Searching
   -m, --mirror   [EDB-ID]    Mirror (aka copies) an exploit to the current working directory
   -x, --examine  [EDB-ID]    Examine (aka opens) the exploit using $PAGER
```

6. Analyse globale de sécurité (Réponses aux questions)

Quels sont les risques identifiés ? L'exposition de services obsolètes permet à un attaquant d'utiliser des exploits publics pour prendre le contrôle du serveur.

Quel service est le plus dangereux ? Dans mon analyse, le service SMB (Port 445) est le plus critique car il permet souvent un accès profond au système de fichiers Windows.

Quelles actions recommanderiez-vous ?

- Appliquer les correctifs (patchs) de sécurité immédiatement.
- Fermer les ports non nécessaires sur le pare-feu.
- Mettre en place une veille de sécurité (OSINT).

❖ **Scan avance**

7. Lien avec l'entreprise

Comment un SOC utilise la Threat Intelligence ? Les analystes comparent les logs du réseau avec des bases comme VirusTotal ou le MITRE ATT&CK pour identifier si une IP qui les contacte appartient à un groupe de hackers connu.

Comment anticiper une attaque ? En surveillant les nouvelles CVE publiées, l'entreprise peut corriger une faille avant que les pirates n'aient le temps de développer un exploit.

8. Conclusion

Ce TP m'a appris que l'information est une arme très essentiel. Savoir qu'un service est ouvert est une chose, mais savoir qu'il existe un exploit public pour ce service change totalement la priorité de défense.

Après ce TP : Je comprends que l'analyse de vulnérabilité est une vision proactive de la sécurité. On ne subit pas l'attaque, on l'anticipe en fermant les brèches connues.